

Chapter 12: Database Security

বর্তমান সময়ে Database একটি প্রতিষ্ঠানের সবচেয়ে গুরুত্বপূর্ণ সম্পদগুলোর একটি। Customer Information, Employee Data, Financial Transaction, Password, Payment Information, Business Report—এসব গুরুত্বপূর্ণ Data Database-এ সংরক্ষিত থাকে।

তাই শুধু Database তৈরি করলেই হবে না; কে Database-এ প্রবেশ করতে পারবে, কে কোন Data দেখতে পারবে, কে Data পরিবর্তন করতে পারবে এবং কোনো User কী ধরনের কাজ করেছে—এসব নিয়ন্ত্রণ করাও অত্যন্ত গুরুত্বপূর্ণ।

এই পুরো প্রক্রিয়াকে বলা হয় Database Security।

সহজভাবে বলা যায়—

Database Security হলো Database-এর Data-কে অননুমোদিত Access, পরিবর্তন, চুরি, অপব্যবহার এবং Data Leakage থেকে সুরক্ষিত রাখার ব্যবস্থা।

একটি শক্তিশালী Database Security Architecture-এর গুরুত্বপূর্ণ অংশ হলো—

- Authentication
- Authorization
- RBAC
- Encryption
- TDE
- Database Vault
- Data Masking
- Auditing

১. Authentication

Authentication কী?

Authentication হলো কোনো User সত্যিই সে যাকে দাবি করছে, সেটি যাচাই করার প্রক্রিয়া।

সহজভাবে—

Authentication = তুমি কে?

ধরুন একজন User Database-এ Login করতে চায়।

Username

+

Password

↓
Authentication

↓
Valid User?

↓
Access Granted

Database User Authentication-এর জন্য বিভিন্ন পদ্ধতি ব্যবহার করা যেতে পারে—

- Username & Password
- Operating System Authentication
- Certificate
- Multi-Factor Authentication
- External Authentication

একটি উদাহরণ

ধরুন একটি Company Database-এ তিনজন User রয়েছে—

Rahim

Karim

Sohag

Rahim Login করার সময় Database প্রথমে যাচাই করবে—

Username = Rahim

Password = *****

তথ্য সঠিক হলে Authentication সফল হবে।

কিন্তু Authentication সফল হওয়ার অর্থ এই নয় যে Rahim Database-এর সব Data দেখতে পারবেন।

এখানেই আসে **Authorization**।

২. Authorization

Authorization কী?

Authorization হলো Authentication সফল হওয়ার পর একজন User Database-এ **কী করতে পারবে এবং কী করতে পারবে না**, তা নির্ধারণ করার প্রক্রিয়া।

সহজভাবে—

Authentication = তুমি কে?

Authorization = তুমি কী করতে পারবে?

উদাহরণ:

User Login



Authentication



User Identity Verified



Authorization



Permissions Checked

ধরুন একজন Accountant-এর জন্য—

SELECT → Allowed

INSERT → Allowed

UPDATE → Limited

DELETE → Not Allowed

অর্থাৎ User Database-এ প্রবেশ করতে পারলেও সব Operation করার Permission তার থাকবে না।

৩. RBAC

RBAC কী?

RBAC (Role-Based Access Control) হলো Role-এর মাধ্যমে User-এর Permission পরিচালনা করার একটি পদ্ধতি।

প্রতিটি User-কে আলাদাভাবে Permission দেওয়ার পরিবর্তে Role তৈরি করে সেই Role-এর মধ্যে Permission নির্ধারণ করা হয়।

User



Role



Permissions

উদাহরণ

একটি Company Database-এ আমরা Role তৈরি করতে পারি—

- DBA

- Developer
- Accountant
- HR
- Report User
- Read-Only User

ধরুন—

DBA

SELECT

INSERT

UPDATE

DELETE

CREATE

ALTER

Report User

SELECT

Developer

SELECT

INSERT

UPDATE

কিন্তু Production Database-এ DROP TABLE করার Permission Developer-এর না থাকাই ভালো।

RBAC-এর সুবিধা

RBAC ব্যবহার করলে—

- Permission Management সহজ হয়।
- একই Role-এর অনেক User সহজে Manage করা যায়।
- Excessive Permission কমানো যায়।
- Employee Role পরিবর্তন হলে Permission Management সহজ হয়।
- Security Policy বাস্তবায়ন করা সহজ হয়।

8. Encryption

Encryption কী?

Encryption হলো Data-কে এমন একটি Encoded বা Protected Format-এ রূপান্তর করার প্রক্রিয়া, যাতে অনুমোদিত Key ছাড়া Data সহজে পড়া না যায়।

সহজভাবে—

Encryption = Data-কে নিরাপদ ও অপাঠ্য Format-এ রূপান্তর করা।

ধরুন Database-এ একটি গুরুত্বপূর্ণ Data রয়েছে—

Customer Account Information

Encryption করলে Data এমনভাবে সংরক্ষিত হতে পারে যাতে সরাসরি Storage থেকে Data পাওয়া গেলেও তা সহজে বোঝা না যায়।

Encryption-এর দুটি গুরুত্বপূর্ণ ক্ষেত্র

Encryption at Rest

Storage-এ সংরক্ষিত Data Encryption করা।

Database



Encrypted Storage

এটি Disk বা Database File চুরি বা অননুমোদিতভাবে Access হলে Data Protection-এ সাহায্য করে।

Encryption in Transit

Network-এর মাধ্যমে Database এবং Application-এর মধ্যে Data Transfer করার সময় Encryption করা।

Application



Encrypted Connection



Database

এর উদ্দেশ্য হলো Network-এর মধ্যে Data Interception-এর ঝুঁকি কমানো।

৫. TDE

TDE কী?

TDE (Transparent Data Encryption) হলো Database-এর Data-at-Rest Encryption করার একটি প্রযুক্তি।

বিশেষ করে Microsoft SQL Server এবং Oracle Database-এর মতো Enterprise Database Platform-এ TDE ব্যবহার করা যায়।

TDE মূলত Database-এর Data File এবং সংশ্লিষ্ট Storage Data Encryption করতে সাহায্য করে।

TDE কেন ব্যবহার করা হয়?

ধরুন একটি Database Server-এর Storage বা Database File কোনোভাবে অননুমোদিত ব্যক্তির হাতে চলে গেল।

যদি Data Encryption না থাকে, তাহলে Database File থেকে Sensitive Information পাওয়ার ঝুঁকি থাকতে পারে।

TDE ব্যবহার করলে Storage-level Data Encryption-এর মাধ্যমে এই ঝুঁকি কমানো যায়।

TDE-এর ধারণা

Application



Database



TDE Encryption



Encrypted Data



Storage

User সাধারণত Application বা Database-এর মাধ্যমে স্বাভাবিকভাবে Data ব্যবহার করবে, কিন্তু Storage Level-এ Data Encrypted অবস্থায় থাকবে।

৬. Database Vault

Database Vault কী?

Database Vault হলো বিশেষভাবে Database-এর ভিতরের Sensitive Data এবং Privileged User Access নিয়ন্ত্রণ করার একটি Security Mechanism।

এটি বিশেষভাবে গুরুত্বপূর্ণ যখন একজন Privileged User বা DBA-এর কাছে Database-এর অনেক ক্ষমতা থাকে।

সাধারণভাবে DBA Database পরিচালনা করতে পারে। কিন্তু Security Policy অনুযায়ী কিছু Sensitive Data-তে DBA-এর সরাসরি Access সীমিত করা প্রয়োজন হতে পারে।

এখানে Database Vault-এর মতো Technology ব্যবহার করা যেতে পারে।

কেন Database Vault দরকার?

ধরুন একটি Banking Database-এ রয়েছে—

Customer Information

Financial Data

Transaction Data

Salary Information

একজন Database Administrator Database Infrastructure পরিচালনা করবেন। কিন্তু Business Policy অনুযায়ী তার সব Sensitive Business Data দেখার প্রয়োজন নাও থাকতে পারে।

Database Vault-এর মতো Security Mechanism ব্যবহার করে Sensitive Data-তে Privileged Access আরও কঠোরভাবে নিয়ন্ত্রণ করা যায়।

৭. Data Masking

Data Masking কী?

Data Masking হলো Sensitive Data-এর আসল Value গোপন রেখে তার পরিবর্তে Masked বা পরিবর্তিত Value প্রদর্শনের পদ্ধতি।

ধরুন Customer-এর Phone Number—

01712345678

এর পরিবর্তে Application-এ দেখানো হলো—

017*****678

এতে User সম্পূর্ণ Sensitive Data দেখতে পারবে না।

কোথায় Data Masking ব্যবহার করা হয়?

বিশেষ করে—

- Development Environment
- Testing Environment
- Customer Support
- Reporting System
- Non-Production Environment

এটি গুরুত্বপূর্ণ।

Development Environment Example

ধরুন Production Database-এ রয়েছে—

Customer Name

Phone

Email

NID

Address

Developer-এর Application Testing-এর জন্য এই বাস্তব Data দেখার প্রয়োজন নেই।

তাই Production Data-এর পরিবর্তে Masked Data ব্যবহার করা যেতে পারে।

Production



Data Masking



Test Environment

এতে Sensitive Data Exposure-এর ঝুঁকি কমে।

৮. Auditing

Auditing কী?

Auditing হলো Database-এ কে কখন কী কাজ করেছে তা Record এবং Monitor করার প্রক্রিয়া।

সহজভাবে—

Auditing = কে কী করেছে তার হিসাব রাখা।

ধরুন একজন User Database-এ Login করলেন এবং একটি গুরুত্বপূর্ণ Table-এর Data পরিবর্তন করলেন।

Audit System থাকলে এই ধরনের তথ্য সংরক্ষণ করা যেতে পারে—

User : SOHAG

Time : 10:30 AM

Action : UPDATE

Table : CUSTOMER

Operation : Data Changed

Auditing-এ কী কী Record করা যেতে পারে?

- Login
- Logout
- Failed Login
- SELECT
- INSERT
- UPDATE
- DELETE
- Permission Change
- Schema Change
- Privileged Activity
- Suspicious Activity

Auditing কেন গুরুত্বপূর্ণ?

কোনো Security Incident হলে Audit Log থেকে জানা যেতে পারে—

Security Incident

↓

Audit Log

↓

Who?

↓

When?

↓

What Action?

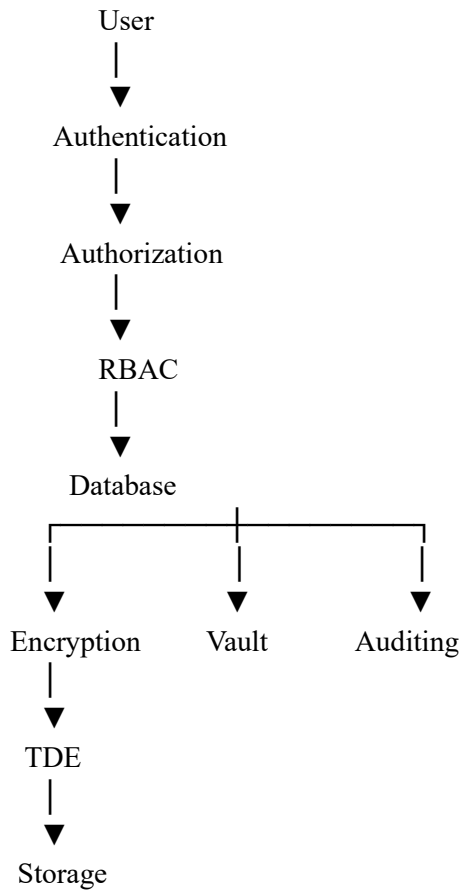
↓

Investigation

এটি Security Monitoring এবং Incident Investigation-এর ক্ষেত্রে অত্যন্ত গুরুত্বপূর্ণ।

Database Security-এর একটি পূর্ণাঙ্গ Architecture

একটি Enterprise Database Security Architecture এভাবে চিন্তা করা যেতে পারে—



Sensitive Data



Data Masking



Development / Testing

একটি বাস্তব উদাহরণ: Banking Database

ধরুন একটি Banking System-এ Customer-এর—

- Name
- Account Number
- Balance

- Transaction
- NID
- Phone Number

সংরক্ষিত আছে।

এখন Security Architecture কীভাবে কাজ করতে পারে?

Step ১ — Authentication

User Login করবে।

Username + Password



Authentication

Step ২ — Authorization

User-এর Permission যাচাই করা হবে।

Can User Access Account Data?

Step ৩ — RBAC

User-এর Role অনুযায়ী Permission দেওয়া হবে।

Teller

Manager

Auditor

DBA

Step ৪ — Encryption

Sensitive Data Encryption করা হবে।

Step ৫ — TDE

Database Storage-এর Data-at-Rest Protection নিশ্চিত করতে TDE ব্যবহার করা যেতে পারে।

Step ৬ — Database Vault

Privileged User-এর Sensitive Data Access আরও কঠোরভাবে নিয়ন্ত্রণ করা যেতে পারে।

Step ৭ — Data Masking

Testing বা Support Environment-এ Sensitive Data Mask করা যেতে পারে।

Step ৮ — Auditing

সব গুরুত্বপূর্ণ Activity Audit করা হবে।

Authentication বনাম Authorization

বিষয়	Authentication	Authorization
উদ্দেশ্য	User কে তা যাচাই	User কী করতে পারবে তা নির্ধারণ
প্রশ্ন	Who are you?	What can you do?
উদাহরণ	Username + Password SELECT / UPDATE Permission	
কখন	প্রথমে	Authentication-এর পরে

Encryption বনাম Data Masking

বিষয়	Encryption	Data Masking
উদ্দেশ্য	Data সুরক্ষিত রাখা	Sensitive Data লুকানো
মূল ধারণা	Data Encrypt করা	Data-এর অংশ পরিবর্তন/Hide করা
সাধারণ ব্যবহার	Storage/Network	Testing/Support/Reporting
উদাহরণ	Encrypted Database File 017*****678	

Database Security-এর Best Practices

একটি নিরাপদ Database Environment তৈরি করতে—

১. Strong Authentication ব্যবহার করুন

দুর্বল Password ব্যবহার করা উচিত নয়।

২. Least Privilege অনুসরণ করুন

User-কে যতটুকু Permission দরকার, ততটুকুই দেওয়া উচিত।

৩. RBAC ব্যবহার করুন

Role-এর মাধ্যমে Permission Manage করা সহজ ও নিরাপদ।

৪. Sensitive Data Encrypt করুন

বিশেষ করে Data-at-Rest এবং Data-in-Transit-এর Security নিশ্চিত করুন।

৫. TDE ব্যবহার করুন

Database Platform এবং Security Requirement অনুযায়ী TDE ব্যবহার করা যেতে পারে।

৬. Privileged Access নিয়ন্ত্রণ করুন

DBA বা অন্যান্য Privileged User-এর Access যথাযথভাবে নিয়ন্ত্রণ করা উচিত।

৭. Non-Production Environment-এ Masked Data ব্যবহার করুন

বাস্তব Sensitive Data সরাসরি Development বা Testing Environment-এ ব্যবহার করা এড়িয়ে চলা উচিত।

৮. Auditing চালু রাখুন

গুরুত্বপূর্ণ Database Activity-এর Audit Trail রাখা উচিত।

৯. Audit Log নিরাপদ রাখুন

Audit Log এমনভাবে সংরক্ষণ করতে হবে যাতে অননুমোদিত User সহজে তা পরিবর্তন বা মুছে ফেলতে না পারে।

অধ্যায়ের সারসংক্ষেপ

Database Security হলো শুধু Password দিয়ে Database Protect করার বিষয় নয়। এটি একটি **Layered Security Approach**, যেখানে একাধিক Security Mechanism একসঙ্গে কাজ করে।

Authentication নিশ্চিত করে User কে।

Authorization নির্ধারণ করে User কী করতে পারবে।

RBAC Role-এর মাধ্যমে Permission Management সহজ করে।

Encryption Data-কে অননুমোদিত Access থেকে সুরক্ষিত রাখতে সাহায্য করে।

TDE Database-এর Data-at-Rest Encryption করতে সাহায্য করে।

Database Vault Privileged User-এর Sensitive Data Access আরও কঠোরভাবে নিয়ন্ত্রণ করতে পারে।

Data Masking Sensitive Data-এর আসল Value গোপন রাখতে সাহায্য করে।

আর **Auditing** Database-এ কে কী করেছে তার Record রাখে।

সবগুলোকে একসঙ্গে বিবেচনা করলে একটি শক্তিশালী Database Security Architecture তৈরি হয়।

Secure Database = Authentication + Authorization + RBAC + Encryption + Access Control + Data Masking + Auditing

একটি Enterprise Database-এর ক্ষেত্রে লক্ষ্য হওয়া উচিত শুধু Data সুরক্ষিত রাখা নয়, বরং কে Data Access করবে, কীভাবে Access করবে, কী করতে পারবে এবং কোনো ঘটনা ঘটলে কীভাবে তা শনাক্ত ও তদন্ত করা হবে—সবকিছুর জন্য একটি সুসংগঠিত Security Framework তৈরি করা।